AI Control Library & Framework Crosswalk

Senthil Nagappan · AI Experience Design & AI Governance · arnsk3@gmail.com · senthilnagappan.com · Last reviewed: August 2026

One internal control set, mapped once, evidenced everywhere

Twelve product-level controls expressed as observable system behaviour, each mapped to ISO/IEC 42001, the NIST AI Risk Management Framework, and the EU AI Act so a single piece of evidence satisfies several obligations. Reference framework synthesized from regulated healthcare, federal, and financial-services delivery; it does not describe a single client engagement.

Control	Product behaviour / evidence	ISO/IEC 42001	NIST AI RMF	EU AI Act
AI governance accountability & ownership	Named owner, reviewers, and exception path per AI use case; three-lines-of-defense map.	42001 §5.3 · A.3	GOVERN 2.1 / 3.2	Art. 17 QMS
AI system inventory & risk classification	Registry entry with intended use, tier, autonomy level, and data sensitivity before build.	42001 A.4 · A.5	MAP 1.1–1.5	Art. 6 + Annex III
Data governance & training-data quality	Provenance, representativeness, and sensitive-attribute handling documented and tested.	42001 A.7	MAP 2.3 / MEASURE 2.8	Art. 10
Technical documentation & model records	Model card, eval results, limits, and change history retained as release evidence.	42001 A.6.2	GOVERN 1.4 / MAP 4.1	Art. 11 + Annex IV
Transparency & user disclosure	AI involvement stated at the moment of use; synthetic content marked.	42001 A.8	MEASURE 2.9 / MANAGE 4.1	Art. 13 · Art. 50
Human oversight & override	Override is as fast as acceptance; rationale captured and routed to monitoring.	42001 A.9.2	GOVERN 3.2 / MANAGE 2.3	Art. 14
Accuracy, robustness & security testing	Acceptance thresholds, adversarial/red-team scenarios, and regression gates per release.	42001 A.6.2.4	MEASURE 2.5–2.7	Art. 15
Post-market monitoring & incident reporting	Drift, override-rate, and harm-signal thresholds with named escalation owners.	42001 §9	MANAGE 4.1–4.3	Art. 72 · Art. 73
Third-party / GPAI supply-chain assurance	Vendor AI due-diligence questionnaire, contract clauses, and shadow-AI discovery.	42001 A.10	GOVERN 6.1–6.2	Art. 25 · Art. 53
AI literacy & workforce training	Role-based literacy tiers for executives, builders, reviewers, and end users.	42001 §7.2	GOVERN 2.2 / 4.1	Art. 4
Accessibility of oversight paths	Every disclosure, explanation, and override path operable via assistive technology.	42001 A.9.2 (extension)	GOVERN 5.1 / MEASURE 3.2	Art. 14 (effective oversight)
Agentic autonomy limits	Autonomy tier caps tool access, spend, and irreversible actions; human confirm gates.	42001 A.6.2.6	MANAGE 2.3 / 4.2	Art. 14 · Art. 15

How to use it

1. Classify at intake — EU AI Act tier plus an internal oversight tier (A/B/C) set the required control depth. 2. Specify each control as user-visible behaviour with an owner, a test, and a retained artifact. 3. Test control effectiveness in the same release gate as functional QA. 4. Monitor override rate, drift, and incident signals in run-state; re-triage on material change.